Verzeichnis von Verarbeitungstätigkeiten – Einträge für „Zeitly" (Art. 30 DSGVO)

Dieses Dokument enthält zwei Einträge:

- **Teil A:** Eintrag für das Verzeichnis des **Verantwortlichen** STEINERfood GmbH (Art. 30 Abs 1 DSGVO) – Verarbeitungstätigkeit „Elektronische Arbeitszeiterfassung".
- **Teil B:** Eintrag für das Verzeichnis des **Auftragsverarbeiters** MALELU AI – Peter Vitzthum (Art. 30 Abs 2 DSGVO) – Kategorie „Betrieb der SaaS-Anwendung Zeitly für Kunden".

Hinweis zur Pflicht: Die Ausnahme des Art. 30 Abs 5 DSGVO (unter 250 Beschäftigte) greift nicht, wenn die Verarbeitung nicht nur gelegentlich erfolgt oder besondere Datenkategorien (Krankenstand) umfasst – beides ist hier der Fall; die Verzeichnisse sind daher zu führen.

Teil A – Verzeichnis des Verantwortlichen (Art. 30 Abs 1 DSGVO)

Feld	Inhalt
Lfd. Nr. / Bezeichnung	[VVT-Nr.] – Elektronische Arbeitszeiterfassung und Abwesenheitsverwaltung mit der Software „Zeitly"
Verantwortlicher	STEINERfood GmbH, Neustift 6, 2224 Sulz im Weinviertel, FN 525885 k (LG Korneuburg), UID ATU75165606; vertreten durch die Geschäftsführung Inge Monika Steiner und Matthias Steiner; Tel. [Telefon], E-Mail [E-Mail]
Vertreter (Art. 27)	nicht anwendbar
Datenschutzbeauftragter	[nicht bestellt / Name, Kontakt]
Fachlich zuständige Stelle	Geschäftsführung; interne Ansprechpartnerin Manuela Behr (Vertrieb) [bzw. Personalverwaltung]
Datum der Anlage / letzte Änderung	[Datum] / [Datum], Version 1.0
Zwecke der Verarbeitung	1. Erfüllung der Aufzeichnungspflicht über Arbeitszeiten und Ruhepausen (§ 26 AZG) 2. Grundlage der Entgeltabrechnung und Führung des Lohnkontos (§ 76 EStG), Ermittlung von Mehr- und Überstunden, Zuschlägen 3. Überwachung der Höchstgrenzen der Arbeitszeit und der Ruhezeiten (§§ 9, 11, 12 AZG; §§ 3, 4 ARG) 4. Urlaubs- und Abwesenheitsverwaltung (UrlG, EFZG, AngG, § 16 UrlG Pflegefreistellung) 5. Dokumentation von Telearbeit (§ 2h AVRAG; Telearbeitspauschale § 26 Z 9 EStG) 6. Projekt-/Kostenstellenrechnung 7. Gewährleistung der IT-Sicherheit und Manipulationssicherheit der Aufzeichnungen
Rechtsgrundlagen	Zwecke 1–5: Art. 6 Abs 1 lit c DSGVO (rechtliche Verpflichtung) und lit b (Erfüllung des Arbeitsvertrags); Krankenstand/Pflegefreistellung: Art. 9 Abs 2 lit b DSGVO iVm EFZG, AngG, UrlG; Zweck 6 und 7: Art. 6 Abs 1 lit f DSGVO (berechtigtes Interesse an betriebswirtschaftlicher Steuerung bzw. sicherem IT-Betrieb). Arbeitsverfassungsrechtlich: Zustimmung der Arbeitnehmer nach § 10 AVRAG (kein Betriebsrat) [bzw. Betriebsvereinbarung § 96 Abs 1 Z 3 ArbVG].
Kategorien betroffener Personen	Arbeitnehmerinnen und Arbeitnehmer (Angestellte, Arbeiter, Lehrlinge, geringfügig Beschäftigte, freie Dienstnehmer), Führungskräfte, Geschäftsführung als Nutzer; externe Lohnverrechnung als Nutzer (Lesezugriff)
Kategorien personenbezogener Daten	Stammdaten (Name, dienstliche E-Mail, Personalnummer, Rolle); Vertragsdaten (Wochenstunden, Arbeitstage, Gleitzeit, Urlaubsanspruch, Eintrittsdatum, Salden); Arbeitszeitbuchungen (Datum, Beginn, Ende, Pausen, Dauer, Art: Arbeit/Reisezeit/Rufbereitschaft, Arbeitsort-Kategorie Büro/Telearbeit/Außendienst); Projekt-/Kostenstellenzuordnung; freiwillige

Feld	Inhalt
	Notizen; Abwesenheiten (Urlaub, Zeitausgleich, Krankenstand, Pflegefreistellung, Sonderurlaub, Fortbildung, unbezahlt); Monatsabschluss-Bestätigungen (Zeitstempel, IP); Anmeldeprotokolle (Zeitpunkt, IP, Browser); Audit-Log; technische Logs. **Nicht verarbeitet:** Standortdaten, Screenshots, Aktivitätsmessung, Diagnosen.
Besondere Kategorien (Art. 9)	Gesundheitsdaten: Tatsache und Dauer von Krankenstand und Pflegefreistellung (keine Diagnose)
Herkunft der Daten	Dienstvertrag/Personalakt (Stamm- und Vertragsdaten); Eingabe durch die betroffene Person selbst bzw. durch Vorgesetzte (Buchungen, Abwesenheiten); automatische Generierung (Protokolle)
Kategorien von Empfängern	Intern: Geschäftsführung, Vorgesetzte (jeweils eigenes Team), Lohnverrechnung. Extern: Auftragsverarbeiter MALELU AI – Peter Vitzthum, Salzburg (Betrieb von Zeitly) mit Unterauftragsverarbeitern Hostinger International Ltd. (Hosting, Frankfurt/DE), Supabase Inc. (Datenbank, Irland), Cloudflare Inc. (DNS/TLS/Proxy, USA), Resend Inc. (E-Mail-Versand, USA); externe Lohnverrechnung/Steuerberatung [Name]; auf gesetzlicher Grundlage: Arbeitsinspektorat, Österreichische Gesundheitskasse, Finanzverwaltung, Gerichte, Behörden.
Übermittlung in Drittländer	USA: Cloudflare Inc. (Verbindungsdaten) – EU-US Data Privacy Framework (Angemessenheitsbeschluss Art. 45 DSGVO) und Standardvertragsklauseln; Resend Inc. (E-Mail-Adresse, Name, Nachrichteninhalt) – Standardvertragsklauseln Art. 46 Abs 2 lit c DSGVO (Durchführungsbeschluss (EU) 2021/914). Arbeitszeitdaten werden ausschließlich in der EU gespeichert. Dokumentation der Garantien: beim Auftragsverarbeiter, auf Anfrage erhältlich.
Löschfristen	Arbeitszeitaufzeichnungen, Abwesenheiten, Vertragsdaten, Monatsabschlüsse, Audit-Log: 7 Jahre ab Ende des Kalenderjahres (§ 132 BAO, § 26 AZG, ASVG-Beitragsgrundlagen), danach Löschung/Anonymisierung; Stammdaten: Sperre bei Austritt, Löschung mit Ablauf der 7-Jahres-Frist; Anmeldeprotokolle und technische Logs: 90 Tage; Einmalcodes: 24 Stunden; Backups: 30 Tage rollierend. Details: Lösch- und Aufbewahrungskonzept Zeitly.
Technische und organisatorische Maßnahmen (Art. 32)	Siehe Anhang 1 des Auftragsverarbeitungsvertrags mit MALELU AI: Anmeldung per Einmalcode, Rollenmodell und Row Level Security, Mandantentrennung, TLS 1.2+, Verschlüsselung at rest, unveränderliches Audit-Log, tägliche verschlüsselte Backups (EU), Least Privilege, Incident-Response-Prozess. Organisatorisch beim Verantwortlichen: Rollen nach Least Privilege vergeben, Austrittsprozess (Sperre am letzten Arbeitstag), Schulung der Vorgesetzten, Verbot der Eingabe von Diagnosen in Notizfeldern, Datenschutzinformation und Zustimmung dokumentiert im Personalakt.
Auftragsverarbeiter / Vertrag	MALELU AI – Peter Vitzthum, Salzburg, office@malelu.io; Auftragsverarbeitungsvertrag vom [Datum]
Datenschutz-Folgenabschätzung	Geprüft am [Datum]: [nicht erforderlich – keine systematische Überwachung, keine Standort-/Verhaltensdaten, Verarbeitung zur Erfüllung gesetzlicher Pflichten; Einordnung nach DSFA-AV BGBl. II Nr. 108/2018 (bitte vor Einsatz prüfen)]
Information der Betroffenen	Datenschutzinformation „Elektronische Arbeitszeiterfassung Zeitly" (Art. 13) ausgehändigt am [Datum]; Zustimmungserklärung § 10 AVRAG im Personalakt
Verknüpfte Verarbeitungen	Personalverwaltung [VVT-Nr.], Lohnverrechnung [VVT-Nr.]

Teil B – Verzeichnis des Auftragsverarbeiters (Art. 30 Abs 2 DSGVO)

Feld	Inhalt
Lfd. Nr. / Bezeichnung	[AV-Nr.] – Betrieb der SaaS-Anwendung „Zeitly" (elektronische

Feld	Inhalt
	Arbeitszeiterfassung) im Auftrag von Kunden (Mandanten)
Auftragsverarbeiter	MALELU AI – Peter Vitzthum, [Straße Nr.], [PLZ] Salzburg, Österreich, office@malelu.io, [Telefon], [GISA-Zahl / UID]
Vertreter (Art. 27)	nicht anwendbar
Datenschutzbeauftragte r	nicht bestellt (keine Pflicht nach Art. 37 DSGVO – Kerntätigkeit erfordert keine umfangreiche regelmäßige Überwachung; bitte bei Wachstum erneut prüfen)
Datum der Anlage / letzte Änderung	[Datum] / [Datum], Version 1.0
Verantwortliche, in deren Auftrag verarbeitet wird	1. STEINERfood GmbH, Neustift 6, 2224 Sulz im Weinviertel, FN 525885 k, Kontakt: Geschäftsführung Inge Monika Steiner, Matthias Steiner, [E-Mail]; AVV vom [Datum] 2. [weitere Mandanten – je Mandant eine Zeile: Firma, Adresse, Kontakt, AVV-Datum]
Kategorien von Verarbeitungen	Hosting und Betrieb der Web-Anwendung; Speicherung in gehosteter Datenbank; Berechnung von Salden und Prüfhinweisen; Erstellung und Bereitstellung von Exporten (CSV/PDF/JSON); Versand von Transaktions-E-Mails; Protokollierung (Audit-Log, Anmelde- und Systemlogs); tägliche verschlüsselte Sicherung; Wiederherstellung; Löschung/Anonymisierung nach Weisung; Support und Fehlerbehebung (Zugriff auf Produktivdaten nur im Einzelfall, protokolliert)
Kategorien betroffener Personen (Information des Verantwortlichen, freiwillig ergänzt)	Beschäftigte der Mandanten, Führungskräfte, Lohnverrechnungs-Nutzer
Kategorien personenbezogener Daten (freiwillig ergänzt)	Stamm- und Vertragsdaten, Arbeitszeitbuchungen, Abwesenheiten (inkl. Krankenstand als Tatsache/Dauer – Art. 9), Projekt-/Kostenstellenzuordnung, Notizen, Monatsabschluss-Bestätigungen, Anmeldeprotokolle, Audit-Log, technische Logs
Unterauftragsverarbeite r	Hostinger International Ltd. (VPS-Hosting, Rechenzentrum Frankfurt/DE); Supabase Inc. (Datenbank/Auth/Backups, AWS eu-west-1 Irland); Cloudflare Inc. (DNS/TLS/Proxy/WAF, USA/global); Resend Inc. (Transaktions-E-Mails, USA). Verträge: jeweils Data Processing Agreement des Anbieters, Stand [Datum].
Übermittlung in Drittländer	USA – Cloudflare Inc.: EU-US Data Privacy Framework (Angemessenheitsbeschluss der Kommission vom 10.7.2023) und Standardvertragsklauseln; Resend Inc.: Standardvertragsklauseln (Durchführungsbeschluss (EU) 2021/914, Modul 3 Auftragsverarbeiter–Unterauftragsverarbeiter), Transfer-Folgenabschätzung dokumentiert am [Datum]. Supabase Inc.: Datenhaltung EU; SCC für etwaigen Fernzugriff durch Support-Personal außerhalb der EU. Keine weiteren Drittlandübermittlungen.
Technische und organisatorische Maßnahmen (Art. 32)	Siehe Anhang 1 des AVV (allgemeine Beschreibung): Einmalcode-Authentifizierung; Rollen und Row Level Security; Mandantentrennung über Mandanten-ID; TLS 1.2+; AES-256 at rest; append-only Audit-Log; tägliche verschlüsselte Backups (30 Tage, EU) mit Wiederherstellungstests; Least Privilege; Secrets ausschließlich in Umgebungsvariablen; Trennung Test/Produktion; Dependency-Scanning und Patch-Management; Incident-Response mit Meldung an Verantwortliche binnen 24 h; jährliche Überprüfung
Aufbewahrung beim Auftragsverarbeiter	Nach Vertragsende: Export 30 Tage, danach Löschung; Backups überschreiben sich nach 30 Tagen; Vertrags- und Nachweisdokumente nach gesetzlichen Fristen (7 Jahre, § 132 BAO / § 212 UGB)
Verzeichnis geführt von	Peter Vitzthum; Überprüfung jährlich sowie bei Änderung von Unterauftragsverarbeitern oder Verarbeitungszwecken

Muster, keine Rechtsberatung – vor Verwendung durch Rechtsberatung prüfen lassen.